

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) · Generated 2026-07-06 · Model: $0.5 \cdot \text{CVE} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{criticality}$

Ranked remediation backlog

#	Coordinate	Version	Band	Risk	Top CVE / issue	Fix
1	com.fastxml...:jackson-databind (typosquat)	2.9.8	CRITICAL	—	Typosquat impersonating jackson-databind (REMOVE)	remove
2	org.apache.logging.log4j:log4j-core	2.14.1	HIGH	7.8	CVE-2021-44228 Log4Shell (10.0)	2.26.1
3	org.apache.logging.log4j:log4j-api	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.26.1
4	com.fasterxml.jackson.core:jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 (9.8) — 50 CVEs total	2.13.4.2
5	com.google.protobuf:protobuf-java (transitive)	3.19.4	HIGH	6.7	CVE-2024-7254 (7.5)	3.25.5
6	com.google.guava:guava	24.1.1-jre	MEDIUM	5.5	CVE-2023-2976 (5.5)	32.0.0-jre
7	commons-io:commons-io	2.4	MEDIUM	5.2	CVE-2021-29425 (4.8)	2.14.0
8	org.apache.commons:commons-lang3	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3)	3.18.0
9	mysql:mysql-connector-java	8.0.30	LOW	2.5	GPL-2.0 license violation (no matching CVE)	8.0.33 + driver swap
10	org.junit.jupiter:junit-jupiter	5.10.2	LOW	1.7	test-scope, 3 majors behind	6.1.1

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted risk
log4j-core	10.0	8.0	2.0	7.8
log4j-api	10.0	8.0	2.0	7.8
jackson-databind	10.0	8.0	2.0	7.8
protobuf-java (transitive)	9.0	6.0	2.0	6.7
guava	6.0	7.0	2.0	5.5
commons-io	5.3	7.0	2.0	5.2
commons-lang3	5.3	7.0	2.0	5.2
mysql-connector-java	0.0	7.0	2.0	2.5
junit-jupiter	0.0	5.0	1.0	1.7

Summary

Band	Count
------	-------

CRITICAL	1
HIGH	4
MEDIUM	3
LOW	2

Priority recommendations

1. **P0** — Remove the typosquatted `com.fastxml.jackson.core:jackson-databind` declaration (supply-chain / dependency-confusion risk).
2. **P0** — Upgrade `log4j-core` and `log4j-api` 2.14.1 → 2.26.1 (Log4Shell, actively exploited RCE, plus 3 newer HIGH-severity CVEs unresolved until 2.25.4+).
3. **P1** — Upgrade `jackson-databind` 2.9.8 → at least 2.13.4.2 (50 known CVEs, 14 CRITICAL gadget-chain RCEs).
4. **P1** — Upgrade or override the transitive `protobuf-java` 3.19.4 (pulled in by `mysql-connector-java`) to ≥ 3.25.5 (3 HIGH-severity CVEs).
5. **P2** — Upgrade `guava` → 32.0.0-jre or later (major — review for API breakage).
6. **P2** — Upgrade `commons-io` → 2.14.0+ and `commons-lang3` → 3.18.0+ (routine, low-effort CVE fixes).
7. **P2** — Resolve the `mysql-connector-java` GPL-2.0-with-FOSS-exception license violation (compliance blocker independent of its LOW CVSS-based risk score); patch to 8.0.33 or replace with a permissively-licensed driver.
8. **P3** — Routine major-version review: `junit-jupiter` 5.10.2 → 6.1.1 (test scope only).

Note on methodology. CVSS data was sourced directly from the live NVD CVE API (exact-version CPE matching) because OWASP Dependency-Check's CLI/Maven plugin and a warm NVD mirror were unavailable in this environment (no `NVD_API_KEY`, no `depscan-dc-data` volume). Dependency-tree, outdated-version, and license findings come from real `mvn dependency:tree`, `versions:display-dependency-updates`, and `license-maven-plugin:add-third-party` runs.

Machine-readable source: `depscan-risk-report.json`. Generated by the *Dependency & Supply-Chain Plugin* — Stage 2.